Fakultät
Angewandte Informatik



FALLBEISPIEL

ISMS Übersicht ChemoDemo AG

Übersicht
ChemoDemo AG

Fantasiestr. 1

4711 München

Dok.nr.: ISMS-0003
Datum: 1.10.2021
Autor: OT-CISO, IT-CISO
Status: gültig

Technische Hochschule Deggendorf
Dieter-Görlitz-Platz 1
94469 Deggendorf

Tel.: 0160 9758 3112

www.th-deg.de
info@th-deg.de

Inhalt

Kurzbeschreibung....2
Übersicht über die IT/OT Infrastruktur....3
Weitere Security Maßnahmen....5
Netzwerksicherheit....5
Weitere Rahmenbedingungen bzgl. Informationssicherheit....7
Security Standards....7
Referenzen: interne Dokumentation....9

Kurzbeschreibung

Die **ChemoDemo AG** (im Folgenden kurz mit ChemoDemo bezeichnet) produziert weltweit Produkte wie Superabsorber etc. und betreibt insbesondere Anlagen für die Polyethylenherstellung (**HLDPE-Anlage** (Low-Density-Polyethylen-Anlage), Polymerisation von Ethen bei niedrigen Drücken).

ChemoDemo beschäftigt ca. 50.000 Mitarbeiter weltweit. Der Konzern wird aus der Firmenzentrale in München heraus gesteuert. In der Firmenzentrale befinden sich u.a. die Abteilungen Finanzen, HR und zentrale IT.
ChemoDemo betreibt 20 Anlagen an 15 Standorten (z.B. Deutschland, England, Kanada, Thailand, China, Argentinien, Mexiko etc.) weltweit. An den Standorten sind **Betriebsleiter** (**Plant Manager**) für den Betrieb der Anlagen verantwortlich.

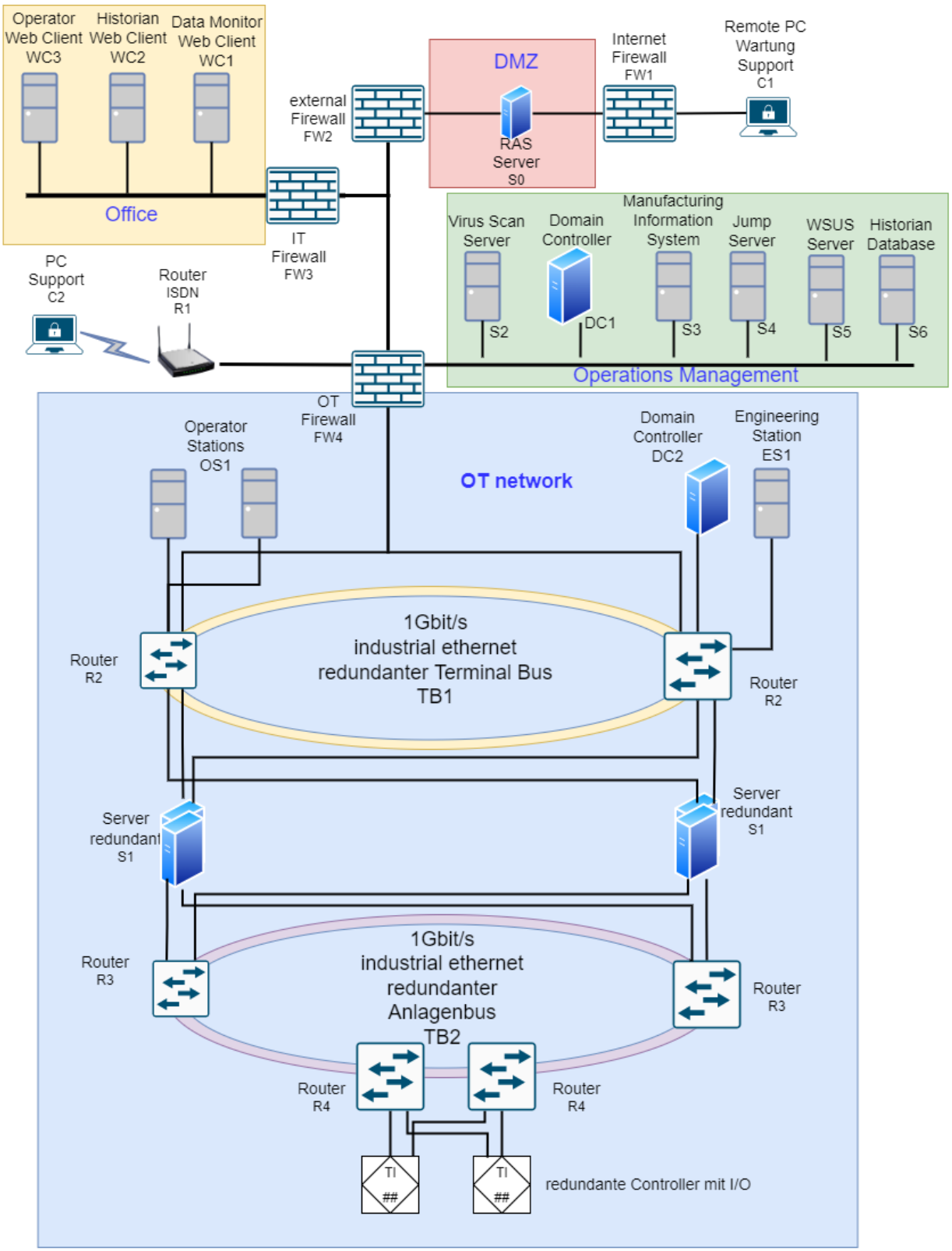
Das Management hat im Jahr 2022 eine Offensive „OT Security and Resilience“ gestartet, um die Security und die Resilienz der IT/OT bzgl. Cyber Attacken zu stärken. Nur so kann gleichzeitig die definierte Digitalisierungsstrategie der ChemoDemo AG umgesetzt werden. Dabei hat das Management die in [CD-0001-Ziele] beschriebenen Ziele vorgegeben. Gemäß den in [CD-0001-Ziele] beschriebenen Zielen sind in das bestehende Information Security Management System (ISMS) zunächst alle LDPE-Anlagen weltweit zu integrieren.

Ein Chief Information Security Officer für die OT (OT-CISO) ist neben dem IT-CISO eingesetzt, um die Offensive „OT Security and Resilience“ voranzubringen. IT-CISO und OT-CISO arbeiten eng zusammen, um die Offensive „OT Security and Resilience“ voranzutreiben. Dabei muss gleichzeitig die Digitalisierungsstrategie von ChemoDemo in alle Aktivitäten bzgl. Security (und Safety) einbezogen werden.

Die Organisationsstrukturen von ChemoDemo AG sind in [CD- ISMS-0002-Organisation] beschrieben.

Übersicht über die IT/OT Infrastruktur[1]

Eine prinzipielle Übersicht über die IT/OT Infrastruktur in Bezug auf die LDPE Anlagen von ChemoDemo zeigt folgende Abbildung 1:



[1] Die IT/OT Infrastruktur für die LDPE-Anlagen ist in Anlehnung an [VDIVDE 2182-Part 3-3], Abschnitt 4.3.1., Bild 2 beschrieben.

Abbildung 1: IT/OT Infrastruktur für eine LDPE-Anlage (siehe Bild 3 aus [VDIVDE 2182-Part 3-3], Abschnitt 4.3.2)

Diese Architektur für die LDPE-Anlagen ist an allen Standorten von ChemoDemo realisiert.

Über die Engineering Station ES1 kann auf die PLCs (TIs) zugegriffen werden. Damit können über die Engineering Station die PLCs konfiguriert und programmiert werden. Die PLCs sind mit einem Sensornetzwerk und den Aktoren zur Regelung der Anlage verbunden (Sensoren und Aktoren sind in Abbildung 1 nicht eingezeichnet). Die Operator Stations OS1 dienen zur Überwachung der Produktionsanalage. Dazu erhalten sie Daten von Sensoren, Aktoren und den PLCs.
Die Server S1 stellen eine Kopplung zwischen dem Terminal Bus Netzwerk TB1 und dem Anlagenbus (TB2) dar. Hierüber kann die Kommunikation zwischen Terminal Bus und Anlagenbus beschränkt und kontrolliert werden (Firewall-Funktion).
Über den Domaincontroller DC1 werden die Windowssysteme OS1, ES1 und S1 administriert und in eine Windowsdomäne eingebunden.

Über Domaincontroller DC2 werden alle Windowskomponenten im Netzwerksegment „Operations Management“ eingebunden und administriert. Über den Virus Scan Server S2 werden aus dem Office Netzwerk die Updates / Pattern Updates für die AntiVirus Scanner geladen und über den WSUS Server auf die Windows-Komponenten des „Operations Management“ Netzwerk, OS1, ES1, DC1, DC2 und S1 verteilt.

Über das Manufacturing Information System S3 (MIS) erfolgen die Arbeitsaufträge an die Produktionsanalage.

Der Jump Server S4 dient als Zwischenstation für den entfernten Zugriff (Remote Access). Benutzer können über das Internet mit einem Client (C1) und über einen von ChemoDemo gestellten Client C2 über den ISDN Router (mit Firewall) R1 auf einen Client im Office Netz WC1 bis WC3 gelenkt werden. Von dort können sie sich dann auf den Jump Server S4 aufschalten. Nur über den Jump Server kann dann auf die Komponenten der Netzwerksegmente „Operations Management“ und TB1 zugegriffen werden.
Für den Remote Access über Client C2 muss der ISDN Router R2 von einem Mitarbeiter der PLT Fachabteilung explizit eingeschaltet werden. Dieser Zugang zum Netzwerk ist für Notfallsituationen vorgesehen.
Auf dem Historian Database Server S6 werden alle gesetzlich verlangten Daten über den Produktionsverlauf gesammelt. Dazu erhält der Server S6 alle relevanten Daten von Sensoren, Aktoren und den PLCs. Die Kommunikation wird über die Server S1 und OT Firewall FW4 bzgl. Protokoll, Port und IP Adresse freigeschaltet. Die Kommunikation darf nur von TB1 und TB2 zum „Operations Management“ Netzwerk erfolgen.

Die Einsatzumgebung der LDPE-Anlagen ist in die Office und IT-Infastruktur wie folgt eingebunden (nach [VDIVDE 2182-Part 3-3], Abschnitt 4.3.2, hier in für ChemoDemo abgewandelter Form):

Die LDPE-Anlage ist eine von mehreren verfahrenstechnischen Produktionsanlagen in einem Chemiepark. Das Gelände wird durch einen Werkszaun geschützt. Zugang zum Gelände kann nur durch manuelle oder per Kamera/Lesegeräte für Werksausweise überwachte Tore erfolgen.

Das Betreiberpersonal überwacht, steuert und regelt die Anlage mithilfe des Prozessleitsystems (PLS: Komponenten im TB1, TB2 und Operations Management) und den Komponenten des Manufacturing- Information-Systems (MIS) und hält die Komponenten instand. Die Betriebsleitung informiert sich über den Zustand der Anlagen durch Auswerten der Daten des MIS an ihren PCs im Büro-Netz (WC1 bis WC3).

Die Sensoren/Aktoren im Feld sind vor Ort nur mit Handwerkszeug zugänglich. Auf Informationen dieser Systeme kann nicht ohne Weiteres vor Ort zugegriffen werden. Ein Zugriff erfolgt in der Regel durch spezielle Geräte mit spezifischer Anwendungs-software.

Die elektrischen Betriebsräume sowie die Schalträume für das Prozessleitsystem sind durch spezielle Schlüsselsysteme (physische als auch RFID Tokens) nur berechtigten Personen zugänglich.

Die IT-Infrastruktur in separaten Räumen ist nur mithilfe eines separaten Schlüsselsystems (physische als auch RFID Tokens) zugänglich. Der Zutritt ist dabei auf Mitarbeiter der IT Fachabteilung beschränkt.

Detaillierte firmeninterne Richtlinien regeln die IT/OT-Sicherheitsanforderungen innerhalb des Werks und alle Mitarbeiter verpflichten sich schriftlich, diese einzuhalten.

Das Office-Netzwerk ist über eine DMZ mit zwei Firewalls (FW1 und FW2), betrieben durch eine IT-Fachabteilung, an das Internet gekoppelt. Das Operations Management Netzwerk ist über Firewall-Systeme (FW3 und FW4), betrieben durch eine IT-Fachabteilung, mit dem Office- Netzwerk verbunden.

Alle Client und Server-Komponenten in den Netzwerksegmenten DMZ, Office, Operations Management, TB1 und TB2 werden mit Microsoft Windows® Betriebssystemen betrieben.

Die Betreuung aller im Prozessleitsystems betriebenen Komponenten einschließlich Router/Switche erfolgt mit eigenem, mit den Gegebenheiten der Einsatzumgebung besonders vertrautem Personal der PLS Fachabteilung.

Weitere Security Maßnahmen

Netzwerksicherheit

Das Netzwerk ist in folgende Netzwerksegmente unterteilt:

- DMZ
- Office Netzwerk

- Operations Management
- Terminal Bus
- Anlagenbus

Die Trennung erfolgt über Firewalls

- Trennung Operation Management Netzwerk – Terminal Bus: FW4, Scalance Firewall, administriert von PLS-Betriebsbetreuung
- Trennung Operation Management Netzwerk– Office Netzwerk: Cisco ASA Firewall, administriert von IT-Abteilung
- Trennung Office Netzwerk – DMZ: Cisco ASA Firewall, administriert von IT-Abteilung
- Trennung DMZ – Internet: Cisco ASA Firewall, administriert von IT-Abteilung

Folgende wesentliche Kommunikationsverbindungen sind realisiert:

ID	Bezeichnung	Beschreibung
1	Remote Access	Die Remote Access Lösung von ChemoDemo ist mittels IPsec realisiert. Es werden die Sicherheitsprotokolle AH und ESP im Tunnelmodus eingesetzt. Die kryptographischen Endpunkte sind die Endgeräte des Mitarbeiters (z.B. eine Engineering Station eines Mitarbeiters eines Service Providers (Zulieferers)) C1 und der RAS Server S1. Die Authentisierung erfolgt mittels Zertifikaten und Kennung/Passwort des Mitarbeiters. Der Mitarbeiter kann sich dann auf den Jump Server S4 verbinden (mittels Kennung/Passwort). Von dort kann sich der Benutzer auf die Engineering Station ES1 weiterverbinden (wieder mit Kennung/Passwort). Von der Engineering Station ES1 kann dann ohne weitere Authentisierung auf die Controller TI zugegriffen werden, um hier z.B. Projekte zu laden.
2	MIS Verbindung	Diese Verbindung kann über ssh von Office PCs WC1, WC2 oder WC3 im Office Netzwerksegment zum MIS Server S3 im Netzwerk „Operations Management“ mittels Kennung/Passwort erfolgen. Auf die PCs WC1, WC2 oder WC3 kann über Remote Access aus dem Internet kommend zugegriffen werden. Vom MIS Server S3 kann sich der Mitarbeiter dann auf den Operator Stations OS1 mittels telnet verbinden (keine weitere Authentisierung notwendig). Von den OS1 Komponenten kann der Benutzer dann auf die Komponenten S1, R2, R3, R4 mit Kennung/Passwort zugreifen.
3	Jump Server zu Komponenten im Operations Netzwerk	Der Remote Access Zugang erlaubt den Zugriff auf den Jump Server S4 (siehe 1). Vom Jump Server S4 (Passwort/Kennung) werden dann alle Komponenten

ID	Bezeichnung	Beschreibung
		im Operations Netzwerk, TB1 und die Server S1 mit Kennung/Passwort erreicht.
4	NTP	Die Zeitsynchronisierung erfolgt über NTP. Der Domain Controller DC1 synchronisiert seine Zeit über den NTP Server (nicht im logischen Netzwerkplan eingezeichnet) im Office Netzwerk. DC2 synchronisiert sich mit DC1. Alle Komponenten im Operations Netzwerk synchronisieren sich über DC1. Über DC2 synchronisieren sich die Komponenten in TB1 und die Server S1. Die Synchronisierung erfolgt immer über NTP.
5	FTP	Das Backup der Engineering Station ES1 erfolgt über die Software Acronis auf die Operator Stations OS1. Einmal in der Woche werden diese Sicherungen via FTP auf den Historian Server S6 geschoben. Die Engineering Server S1 halten alle Konfigurationen und Programme der PLCs. Diese Daten sind in das Backupverfahren von Acronis einbezogen.

Weitere Rahmenbedingungen bzgl. Informationssicherheit

Folgende wesentliche Rahmenbedingungen bzgl. Informationssicherheit sind damit gegeben:

- Alle Komponenten (PLCs ausgenommen) werden mit aktuellen Microsoft Windows Betriebssystemen (Server: Windows Server 2019, Operating und Engineering Stations: Windows 11) nach einem Härtungskonzept des Systemintegrators installiert und konfiguriert. Die Mitarbeiter von ChemoDemo kennen dieses Härtungskonzept aber nicht.
- Minimale Installation: es wird nur Software installiert, die auch benötigt wird. Jedoch werden nicht benötigte TCP Ports nicht deaktiviert.
- Virenschutz: es ist ein Virenscanner installiert; das Pattern-Update erfolgt einmal im Jahr, wenn ein Wartungsfenster genutzt werden kann
- Eine Deaktivierung von USB Schnittstellen ist nicht umgesetzt
- Mobile Devices dürfen nicht eingesetzt werden: dies wird durch eine Richtlinie verboten; diese Richtlinie muss auch von den Zulieferern / Service Providern unterzeichnet werden.
- Die Mitarbeiter der PLS-Fachabteilung besuchen einmal im Jahr einen eintägigen Security-Kurses
- Ein Prozess für die Behandlung von Security Vorfällen ist nicht definiert
- Security Audits wurden bisher nicht durchgeführt

Security Standards

Folgende Standards (siehe Tabelle 1) wurden als Grundlage für den Aufbau und Betrieb eines Information Security Management Systems (ISMS) identifiziert:

Nr.	Standard	Titel

D1	ISO/IEC 27001 Second edition	Information technology — Security techniques — Information security management systems — Requirements, INTERNATIONAL STANDARD, ISO/IEC 27001, Second edition, 2013-10-01
D2	ISO/IEC 27002 Second edition	Information technology — Security techniques — Code of practice for information security controls, INTERNATIONAL STANDARD, ISO/IEC 27002, Second edition, 2013-10-01
D3	ISO/IEC 27005, First edition	Information technology — Security techniques — Information security risk management, INTERNATIONAL STANDARD, ISO/IEC 27005, First edition, 2008-06-15
D4	ISO 22301	ISO 22301:2012, Societal security -- Business continuity management systems --- Requirements, May 2012
D5	IEC 62334-2-1, Draft 7, Edit 5	Security for industrial automation and control systems, Part 2-1: Industrial automation and control system security management system, Draft 7, Edit 5, November 9, 2015
D6	IEC 62443-3-3 Corrigendum 1: 2014	Industrial communication networks – Network and system security, Part 3-3: System security requirements and security levels

Tabelle 1: als relevant identifizierte Standards

Referenzen: interne Dokumentation

Siehe [CD-0002-interneReferenzen]